

Vulnerability Assessment Report

Read-Only Security Inspection Baseline

TARGET WEBSITE	demo.testfire.net (Altoro Mutual Sandbox)
ASSESSMENT TYPE	Passive Vulnerability Assessment (Read-Only)
ASSIGNED SCOPE	Strictly Non-Intrusive, Header Validation, Port Analysis
TOOLS UTILIZED	Nmap (Service Footprinting), OWASP ZAP (Passive Rules), Browser DevTools

DATE OF AUDIT : May 21, 2026

PREPARED FOR : Future Interns Task Requirements

PREPARED BY : PRIYADHARSHINIS

Confidentiality Statement

This document is the exclusive property of the assessor and **Future Interns**. It contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, requires prior written consent. This report may be shared securely with authorized personnel and internal auditors under non-disclosure agreements solely to demonstrate compliance with academic or organizational security assessment requirements.

Disclaimer

This vulnerability assessment is a static snapshot in time. The findings, exposures, and recommendations detailed within reflect exclusively the information gathered during passive analysis and cannot account for infrastructure changes, code updates, or configuration modifications made after the execution window.

The scope of this audit was strictly limited to passive techniques — absolutely no active exploitation, fuzzing, brute force, credential stuffing, or denial-of-service attacks were performed. To maintain a resilient defense profile, it is highly recommended to perform matching comprehensive assessments annually or post major code deployments.

Scope & Boundary Conditions

The operational framework of this assessment was constrained to the following boundary parameters:

Allowed Passive Activities	Explicitly Excluded Activities
• Passive traffic monitoring via OWASP ZAP • Response header analysis • Cookie attribute verification via DevTools • Basic external port/service exposure discovery	• Active payload injections (SQLi, XSS) • Authentication bypass or brute forcing • Denial-of-Service (DoS / DDoS) simulations • Automated intrusive vulnerability fuzzing

Executive Summary

A strictly passive, read-only security vulnerability assessment was executed against demo.testfire.net. The objective was to establish a foundational security baseline by analyzing public-facing infrastructure profiles, reviewing missing or malformed HTTP response headers, and auditing cookie tracking mechanisms.

The passive telemetry indicates critical structural remediation areas necessary to prevent target fingerprinting, session mishandling, and insecure transportation vectors.

Risk Classification Summary

Risk Severity	Alert Count	Identified Mappings
HIGH	1	Insecure Session Cookies (Missing SameSite)
MEDIUM	2	Missing Core Security Headers, Insecure HTTP Connection
LOW	1	Information Disclosure via Public Directory Listings

Infrastructure Mapping & Port Discovery

External port footprinting identified exposed management ports operating alongside primary web interfaces. Specifically, port 8080/tcp is actively exposed to the public internet.

Port	State	Protocol	Framework / Banner Exposed
80/ tcp	Open	HTTP	Apache Tomcat / Coyote JSP 1.1
443/ tcp	Open	SSL/ HT TP	Apache Tomcat / Coyote JSP 1.1
8080/ tcp	Open	HTTP	Apache Tomcat / Coyote JSP 1.1

Risk: Publicly exposing unhardened management/development ports (8080) and raw Apache Tomcat banners provides malicious actors with clear infrastructure mapping parameters, narrowing down vector paths for known legacy exploits.

Remediation Strategy: Apply firewall layer restrictions to drop incoming traffic on port 8080 except from explicit administrative source IPs. Suppress server production tokens in the Tomcat configuration files (server.xml) by overriding the `server` attribute.

```
C:\Windows\system32\cmd.exe
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 08:22 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.0061s latency).
Not shown: 939 filtered tcp ports (no-response), 57 filtered tcp ports (host-unreach)
PORT      STATE SERVICE VERSION
80/tcp    open  tcpwrapped
443/tcp   open  tcpwrapped
8080/tcp   open  tcpwrapped
8443/tcp   closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.62 seconds

C:\Users\hp>nmap -Pn -sV -oN nmap_results.txt demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 08:23 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.014s latency).
Not shown: 860 filtered tcp ports (no-response), 137 filtered tcp ports (host-unreach)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.42 seconds

C:\Users\hp>
```

Figure 1: Nmap Port Audit output confirming open port 8080 and Tomcat platform banner disclosure.

Detailed Findings & Analysis

1. Insecure Cookie Attributes

HIGH

Description: The primary `JSESSIONID` session identifier cookie is missing the `SameSite` protection attribute flag.

Impact: Makes session states vulnerable to Cross-Site Request Forgery (CSRF) and cross-site session hijacking tricks, allowing malicious sites to submit requests on behalf of an authenticated context browser.

Recommendation: Modify the application context configuration or header injection rules to include a strict explicit directive: `SameSite=Lax` or `SameSite=Strict`.

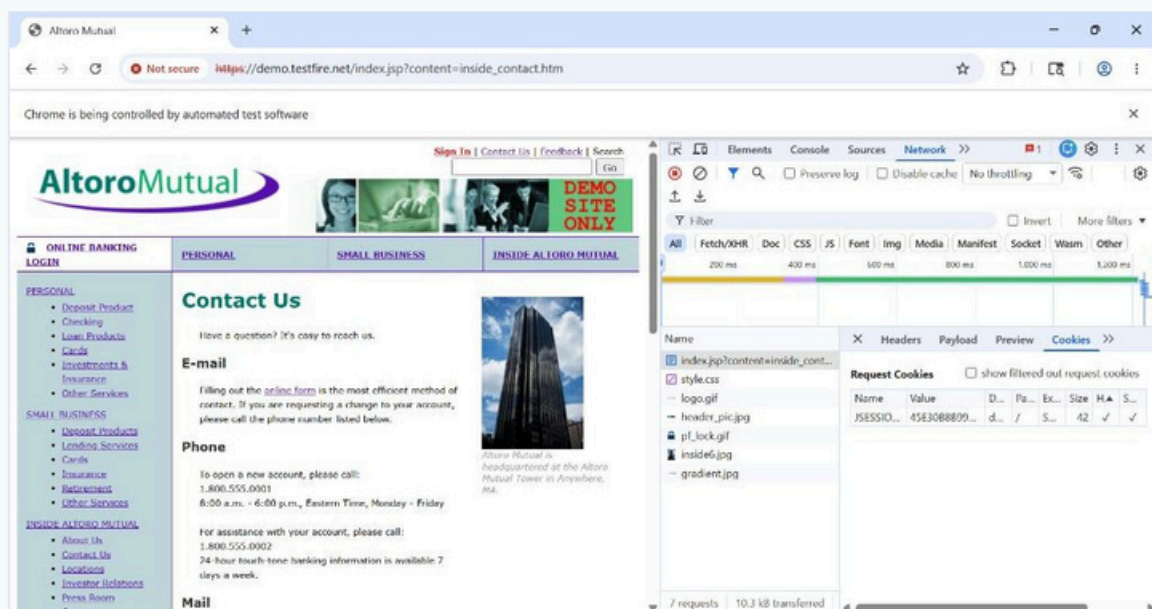


Figure 2: Browser Developer Tools Network Inspection validating `JSESSIONID` cookie missing `SameSite` flags.

2. Absent Core Security Headers

MEDIUM

Description: The remote server fails to return critical browser security directives, notably HTTP Strict-Transport-Security (HSTS) and X-Content-Type-Options.

Impact: Facilitates man-in-the-middle protocol downgrades and lets client browsers run unsafe Multipurpose Internet Mail Extensions (MIME) sniffing configurations on scripts.

Recommendation: Configure response header interceptors to output:

Strict-Transport-Security: max-age=63072000; includeSubDomains
X-Content-Type-Options: nosniff

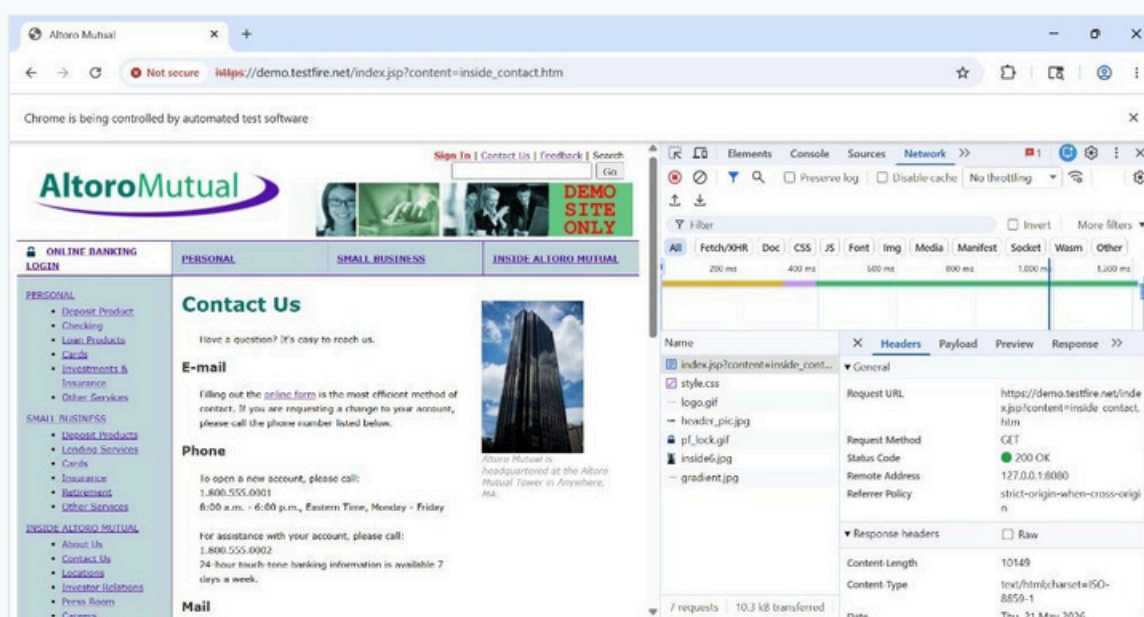


Figure 3: DevTools Response Headers inspection confirming complete absence of HSTS and security flags.

MEDIUM

Impact: Passwords, session parameters, and submitted data transmit completely in plaintext over the wire, exposing users to basic local network snooping.

Figure 4: Browser 'Not Secure' validation banner during plaintext HTTP transit.

Figure 4: Browser 'Not Secure' validation banner during plaintext HTTP transit.

4. Information Disclosure & Directory Resource Leaks

LOW

Description: Passive site crawling tracked index listings and generic paths left unsecured, revealing backend build layouts.

Impact: Gives bad actors detailed layout blueprints, making target reconnaissance easy.

Recommendation: Enforce Directory Browsing Disabled policies in web server configuration files and return standard custom 403/404 handling pages.

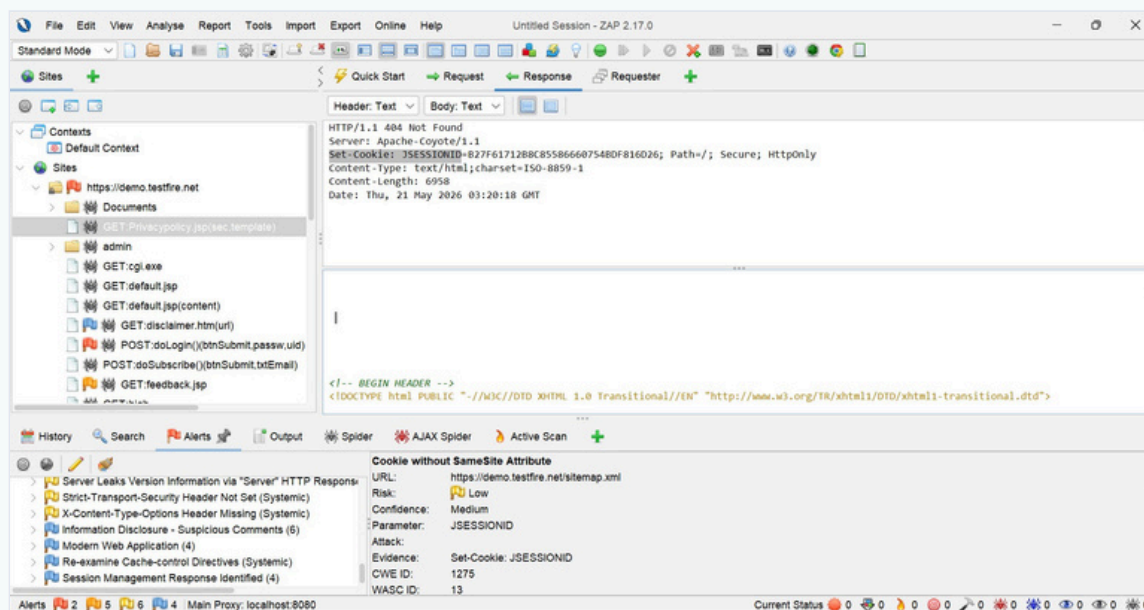


Figure 5: OWASP ZAP Passive Scan Rules Engine flags and structural crawl mapping tree.

Recommendations Summary Masterlist

- **Inject Client Protection Headers:** Add comprehensive CSP, HSTS, X-Frame-Options, and X-Content-Type-Options layers inside the reverse proxy or endpoint pipeline.
- **Strengthen Session Flags:** Set cookie properties explicitly to Secure, HttpOnly, and SameSite=Lax.
- **Enforce Global Cryptographic Transport:** Terminate plain HTTP connections by auto-forwarding actions into port 443 via an SSL certificate.
- **Minimize Reconnaissance Footprints:** Turn off indexed directory queries, disable path tracking, and strip detailed server platform tags from outward headers.
- **Restrict Port Exposure:** Use hardware or software firewalls to drop wide requests on development port 8080.

Conclusion & Strategic Next Steps

The issues mapped out in this passive assessment represent fundamental server setup and architecture validation gaps rather than direct active code breaks. Resolving these minor configuration points creates strong defenses, making it difficult for automated mapping engines to target the system or take advantage of unencrypted traffic.